

Stack 06 audit: runtime clear-signing and predecessor security reconciliation

1. Identity, scope and acceptance boundary

Owner: Codex /root in keepkey-vault-v11-agent-1. Branch: audit/715-stack06-agent1-reconcile. Isolated worktree: /private/tmp/kk715-stack06-agent1-audit. Canonical coordination: main firmware docs/release/audit-claims/715-06/OWNER.md. The untracked canonical evidence was copied and hashed before use; its intake snapshot remains under /private/tmp/kk715-stack06-intake-evidence/canonical-release. The historical intake report records the master form hash and the failed assertions that drove this remediation.

Accepted immediate audit predecessor: Stack 05 PR #858, audit/715-stack05-review at 5c3f2d927f56a8646178d00c0abc9ed01c427393. Frozen implementation/check-script head: fad2d0c4af0e186a9e16837cd844413feb552306. Inventory generation predecessor: f49c68ccf. The containing final report head and exact hosted CI status are recorded in the audit PR description, since this report cannot embed its own commit hash.

Historical product PR #836 still compares b771669ba842d83790a69b6132f63cea82e5a861 against old Stack 05 dc644600361da15a123f0d50605220cccadd8de3. This reconciled code-bearing audit targets the completed Stack 05 audit branch. It does not rewrite either historical product branch, merge develop, or claim the assembled release contains all accepted earlier checkpoints. Stack 04's older Stack 03 lineage remains a separate assembled-product integration gate.

The finite batch preserves the original 26-file Stack 06 unit, requalifies its three prior local fixes, and repairs the inherited transport, Ripple, policy and workflow regressions reproduced on this predecessor. Runtime signer loading is inherited. The direct diff changes EIP-712 helpers, liquidity review, exact-byte display plumbing, dispatch/workflow authorization, trust lifetime and their tests. Structured EIP-712 signing stays disabled. No new chain, storage-format redesign or trusted firmware signer is enabled.

Status at report generation: implementation, targeted verification, full/BTC local integration and the scoped adversarial checks pass. Hosted exact-head CI and external review delivery are recorded separately in the PR/claim. Physical USB/controller behavior, physical OLED/buttons, signed-device upgrade, complete release assembly and promotion remain pending. This is an audit-unit report, not release approval.

2. Current-source security closure matrix

ID	Value, observer, variants and phase	Allowed / forbidden behavior; actual path and evidence
B06-001	Seed-derived root/partial HDNode; RAM observer; full; failed liquidity derivation	Derived keys may exist only while needed. zx_getDerivedNode wipes before reuse and on root-load/CKD failures; confirmFromAccountMatch wipes after hashing. The real implementation is linked through a test-only fault probe. Root-load, partial CKD and invalid-curve-after-success assertions pass. Removing wipes makes the test fail. BTC excludes this engine. Fixed and targeted verified.
B06-002	Tiny credential acknowledgments and packet buffers; host/RAM observer; both variants; receive/unwind	One failure must unwind without another host packet, and accepted/rejected secrets must not remain in static buffers. Actual UDP blocking/nonblocking entry tests pass; messages_probe inspects the real private tiny buffer after copying the secret. Removing its wipe fails both variants. Production main/debug callback bodies run against fault-injected complete, short, empty and error reads and clear their buffers; this is a host callback harness, not physical controller proof. Fixed and software verified.

B06-003	Untrusted runtime metadata; user observing amount/calldata/fee; full; consent/signature	Metadata may add explanation, never suppress baseline transaction review. ethereum_signing_init preserves ordinary screens and transaction binding. Five host assertions cover v1/v2, all runtime slots, bad signature and absent signer. Suppression mutation fails three assertions; two unaffected controls pass. Captured v1/v2 baseline screens inspected. BTC excludes EVM. Fixed and adversarial verified.
B06-004	AdvancedMode and loaded provider keys; flash/RAM; both variants for policy, full for signer; lock/Initialize/reboot	Flash cannot resurrect AdvancedMode; explicit lock and disabling policy revoke trust. Soft Initialize retains policy but drops signers. Storage ignores burned bit 12, scrubs stale records and rejects legacy policy-name shadowing. Native flash/lock tests and host Initialize/ClearSession/disable tests pass. Two unchanged host power-cycle assertions pass with explicitly owned Popen handles, preserving flash and checking seed/marker survival. Device enumeration under qemu was replaced only in the harness; firmware assertions were unchanged. Metadata handler now explicitly refuses use outside AdvancedMode. Fixed.
B06-005	Host Ripple memo; signed wire bytes and user display; full; review/sign	Complete memo bytes must be displayed and serialized with the correct length prefix. fsm_msgRippleSignTx uses complete paging; ripple_serializeVarint includes 192 in the one-byte range. Independent 191/192/193/199-byte native and host vectors pass. Host MemoData field expectation corrected to 0x7D. The 199-byte TAIL0199 suffix is visible on Memo 2/2. BTC intentionally excludes Ripple. Fixed.
B06-006	Authorized signing/recovery state and derived scratch; host/RAM observer; both variants; progress/interrupt	Valid Bitcoin stages, recovery edits, EVM chunks and EOS actions renew idle deadlines. Polling, incomplete/invalid input and empty continuations do not. Protected Ping/top-level interruptions end prior workflows; dispatch cleans scratch and rejects cross-workflow acknowledgments. All formerly guarded Fsm/AutoLockProgress assertions now compile and pass normally. Full: 488 firmware tests; BTC: 134. Inherited reset/recovery/Bitcoin host suites also pass. Fixed; arbitrary physical fault injection remains outside the software checkpoint.
B06-007	ERC20 approval authority; user; full; classification/review	Padded zero, nonzero native value, trailing bytes and a split initial chunk cannot bypass unlimited-approval refusal. Detection checks the approval prefix independently of native value and before contract/generic confirmation. Possible approval prefixes require the first 68 bytes in the initial chunk; unrelated streaming calls keep their prior behavior. Actual signing-path regressions and full host signing/approval checks pass. This policy is unchanged from the retained release contract. Prior Hive symbol/memo failures are inherited, unaffected source and explicitly staged under hive-release-review; they remain a later-unit/release obligation, not a resolved Stack 06 defect.
B06-008	Host typed JSON, hashes and display; full; parser/helper calls	EIP-712 parser/helpers and domain-primary-type tests execute; the production structured signing gate still returns false. No supported structured-signing claim follows from helper tests. THOR percentage formatting and liquidity canonical-shape/display vectors execute in the full suite. Current bounded capability verified; enabling structured signing requires its own unit.

B06-009	Exact message bytes and display; both variants; paging	Orphan tests expected an absent API and were not compiled. Replace them with registered tests of the actual escaping/page API: all 256 bytes, escaped controls/backslash, pagination and a trailing marker. Remove only the uncompiled duplicate driver implementation; keep its used header and the compiled confirm_test_utils implementation. Both variants pass. Verification gap fixed without changing the display policy.
---------	--	--

The dedicated hosted Stack 06 contract invocation clears the later capability skip list only for the three selected metadata/trust/Ripple modules. This prevents erc7730-runtime-review from hiding already implemented legacy runtime-metadata contracts. Ordinary broad-run skips remain explicit in the named TSV, including staged later features. No global skip or failing assertion was weakened to qualify this unit.

3. Verification, artifacts and limits

Pinned builder: kktech/firmware@sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2. Corrective native, broad host and ARM checks cover the revised code; the final allowance changes are exercised by the full native, ARM and host reruns. Bitcoin-only excludes the changed engine and new tests; its preceding passing checks remain applicable and CI repeats both variants. Earlier OLED, owned reboot and key/transport negative controls are retained for unchanged paths; hosted CI repeats native/host/OLED on the containing final head. Hosted CI must validate the final containing report head; local totals alone are not an exact-head hosted pass.

Check	Result	Evidence / limits
Full native	PASS: firmware 488, board 19, crypto 18, Zcash crypto 72	allowance-final-native-full.log, allowance-final-full.xml; other native suites in corrective-native-full.log; actual hidden-policy tests are now ordinary tests
Bitcoin-only native	PASS: firmware 134, board 19, crypto 18	corrective-native-btc.log, corrective-btc.xml; altcoin engines absent
Full host	PASS: 653, SKIP: 178	host-allowance-final-full.xml; matching emulator, complete pinned host tree, explicit staged capabilities
Bitcoin-only host	PASS: 347, SKIP: 484	host-corrective-btc.xml; all five owned storage upgrade/reboot cases pass
Focused contracts	PASS: 20, SKIP: 3	Five additive tests, Ripple memo/boundaries, EVM guards and session tests. Two discovery-limited reboot skips closed by the next row; old-version memo-refusal case intentionally skipped
Owned trust reboot	PASS: 2, SKIP: 0	powercycle-owned.log and owned-powercycle.py; original assertions, explicit owned process lifecycle
Full OLED report	PASS: 99, SKIP: 89; 527 frames	Capture manifest and screenshot audit pass; excluded capabilities remain skipped
BTC OLED report	PASS: 40, SKIP: 148; 216 frames	Capture manifest and screenshot audit pass
Focused OLED	PASS: 3; 42 frames	Ripple length boundaries and v1/v2 additive metadata; selected frames visually inspected
ARM MinSizeRel full	PASS: text 585344, data 3428, bss 100620 bytes	ELF/BIN retained externally with SHA256; linker RAM reserve gate passed
ARM MinSizeRel BTC	PASS: text 360096, data 3284, bss 86588 bytes	Same builder/product flags; linker RAM reserve gate passed
Negative controls	Expected failures detected	Tiny-buffer wipe both variants; private-key wipe full; metadata suppression full; strict domain guards full; earlier tiny-rejection rollback also failed

Report/automation	PASS	Combined native+host SECTIONS validation both variants; six report-validator tests; actionlint; shell syntax; code-bearing diff gate; whitespace check
-------------------	------	--

All 662 broad-run skipped test names and reasons are in 715-06-skips-20260924.tsv. These totals overlap the focused runs and must not be added as unique coverage. Session power-cycle assertions have explicit separate completion evidence. Physical unplug/replug remains a release gate. Historical reports and intake failure logs are preserved as historical evidence, not assertions that the current code still fails.

Validation bundle: 715-06-validation-20260924.tgz. File digests, including external ARM ELF identities, are in 715-06-validation-sha256-20260924.txt. Binaries are retained under /private/tmp/kk715-stack06-intake-evidence/arm-full and arm-btc rather than committed. Failed initial harness/build attempts are distinguishable from the final receipts; the host source-mount problem and missing C declaration were corrected before the passing runs.

4. Dependency pins and provenance

Path	Pinned commit	Disposition
deps/crypto/trezor-firmware	8a392f70a5d5575ece3dfb35f115d4a4b27f497c	unchanged
deps/device-protocol	dd9c85dc747cf965fb0e7bf49615dc9e7568ee65	unchanged
deps/python-keepkey	b745562be6a13cc83b2a547d7ef86637f4556dbb	Ripple test oracle/boundaries; published to BitHighlander fork; .gitmodules URL follows it
deps/python-keepkey/keepkeylib/eth/ethereum-lists	89a64f717e1690bb31adb3e4c38e23640357333c	unchanged nested pin
deps/googletest	7888184f28509dba839e3683409443e0b5bb8948	unchanged
deps/qrenc/QR-Code-generator	6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8	unchanged
deps/sca-hardening/SecAESSTM32	71d356a1141624994cf613bd2d2583892e8e6d5a	unchanged
code-signing-keys	a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec	unchanged

4a. Delivered review, remediation and retrospective

Initial code-bearing review: Copilot 5299708246 on f274e6b1684488102ca92caca69d86a171097657, verdict Changes recommended, Lite effort, five inline findings. CI run 35952907048 passed all required jobs on that initial head. That head is superseded and is not the accepted candidate. The one allowed corrective request subsequently delivered the second review described below; no third request is authorized without renewed owner direction. Balanced effort is recommended for firmware security reviews; no setting change is claimed.

Finding / channel	Disposition and evidence
4089838022: short byte strings	Original logical-OR short-circuiting already prevents the alleged reads for empty and one-character strings. Added an explicit total-length guard for clarity and a dedicated short-buffer regression covering both encoders. Defensive change; no reproduced out-of-bounds claim.
4089838047: domain verifyingContract	Fixed. Restore predecessor exact 20-byte hex validation independently of the host-declared type before summary use. Wrong-length and non-hex string-domain tests fail closed. The removed-guard negative control fails the new test.
4089838077: variant linkage	Refuted. Full CMake source list already includes signed_metadata.c; fsm.c supplies signed_metadata_clear_signers under the Bitcoin-only branch. Both ARM product ELF's and both emulator/native products linked on the reviewed head and again after remediation. No source-list or stub change is needed.
4089838100: domain chain ID	Fixed. Restore predecessor canonical uint32 parser, including complete consumption and overflow refusal. Malformed string-domain cases and UINT32_MAX success execute. Removing the guard fails the test.

4089838128: printf evidence text	Clarified. snprintf is a historical newlib integer-only API name, but the current build has no global remap. The old capture document now describes the actual snprintf integer math and no longer claims a current remap.
Body: EIP-712 state/canonical values	Fixed. Domain summary uses cancellable confirmation; encode clears borrowed domain/name pointers at entry and on every return. Tests cancel a marshalled value, free the prior JSON, then successfully encode a domain that omits it. Integer text rejects leading zeros and negative zero; dedicated malformed-decimal cases pass. Structured signing remains disabled.
Body: legacy policy upgrades	Fixed. Only the historical ShapeShift policy is migrated by its exact known name after default reset. AdvancedMode and other injected names cannot shadow compiled policies. The legacy fixture again proves the existing preference survives, while the injection regression stays active.
Body: removed Ethereum coverage	Fixed. All 16 deleted predecessor tests are restored, with their original assertions, alongside the new liquidity coverage. This restores chain bounds, nonblank formatting, contract fallback, token-chain scoping, structured-signing disablement and canonical domain checks.

Retrospective: the first local audit missed security helper and test deletions introduced by the replay, despite successful builds and disabled production structured signing. Passing totals did not establish predecessor preservation. The corrective adjacent review checked those deletions directly, restored the prior contracts, and tested the new failure paths. At that corrective head, full native ran 485 firmware tests (16 restored, six new); Bitcoin-only remains 134. Local full/BTC host totals are unchanged with zero failures. Physical-device and assembled-release gates remain separate.

Second review and final local repair

Corrective review 5300506855 on 8ed653517a63278891353bcf939a9c3108feacb2 returned Changes recommended with one new inline finding, 4090501368: nonzero native value bypassed unlimited-allowance refusal. It acknowledged all five initial inline findings as resolved. The summary also names policy migration, parser, host configuration and transport coverage without additional concrete locations or defect statements; the prior body dispositions and explicit coverage limits remain recorded above.

The new finding was reproduced through the real ethereum_signing_init path: the old firmware reached a generic confirmation. Commits 0b9031cae, 6869694bb and fad2d0c4a separate the approval-prefix predicate from native-value display classification and also close equivalent split/trailing-calldata bypasses. Three actual signing-path tests require refusal before any confirmation and signing-state cleanup. Full native now passes 488 firmware tests; the old implementation fails all three new regressions. Possible approval selector prefixes require at least 68 initial bytes so the allowance is available before confirmation. Splits at 1, 2, 3, 4, 16 and 67 bytes are refused. An initially broad restriction broke the existing Ethereum streaming-progress test; it was narrowed to possible approval prefixes, preserving that test unchanged.

Two Copilot requests have been spent. No current-head clean external review or owner exception is claimed. The last delivered verdict remains Changes recommended; fixing and resolving its finding does not turn that historical review into a clean current-head review. The implementation and validation work may be handed off with the actual review history, but a further external review request requires renewed owner direction under REHEARSAL-SOP. Physical-device and release gates remain separate.

5. Historical units and final adjacent inventory

Each historical commit can be reproduced with `git show --format= --numstat --no-renames COMMIT`. The companion 715-06-history-20260924.tsv contains every path and count for each listed commit. Counts include tests/docs and dependency pointer lines; binary counts are omitted from numeric sums. Historical counts overlap and are not the net audit diff.

Commit	Files	Added	Deleted	Change and purpose
b771669ba	26	1501	1006	release(7.15): linear stack 06
e5bd8499b	1	9	2	fix(ethereum): wipe static liquidity derivation node on failure
2263bdce0	2	48	1	fix(transport): terminate rejected tiny acknowledgements and wipe buffer

c20dab14d	1	12	7	fix(ethereum): keep baseline review for runtime metadata
ba52d68b6	2	10	2	fix(fsm): abort stale signing before protected Ping
c2ddc0656	3	87	15	fix(storage): keep AdvancedMode within unlocked session
2831f91b5	2	19	15	fix(signing): renew idle deadline on accepted Bitcoin stages
ae4061a6f	5	50	16	fix(fsm): restore dispatch and workflow policy boundaries
4bed97271	4	34	10	fix(ripple): restore 7.15 memo signing and full display
de8e97cb3	10	135	136	fix(715): repair Stack 06 trust lifetime and review boundaries
1258aee56	9	152	2	fix(715): enforce metadata opt-in and verify transport cleanup
d7d149c46	1	11	0	test(ci): require Stack 06 contracts despite later capability skips
1ebb3b8ec	7	573	81	fix(audit): preserve predecessor domain and legacy policy protections
0b9031cae	2	88	4	fix(ethereum): refuse unlimited approvals independently of native value
6869694bb	2	43	7	fix(ethereum): apply allowance policy to streamed and trailing calldata
fad2d0c4a	2	43	36	fix(ethereum): preserve unrelated streams while rejecting partial approvals

The exact net inventory below is generated with `git diff --numstat 5c3f2d927f56a8646178d00c0abc9ed01c427393..f49c68ccf`. It includes every source, test, dependency, workflow and documentation path, plus report/PDF and evidence artifacts when frozen. Binary paths show dashes. Report-only regeneration changes no implementation. Verify the containing final head against this list before external review.

Adjacent path	Added	Deleted
.github/workflows/ci.yml	4	1
.gitmodules	1	1
deps/python-keepkey	1	1
docs/release/audit-units/715-06-evidence-sha256-20260924.txt	20	0
docs/release/audit-units/715-06-history-20260924.tsv	80	0
docs/release/audit-units/715-06-intake-evidence-20260924.tgz	-	-

docs/release/audit-units/715-06-reconciliation-20260924.md	140	0
docs/release/audit-units/715-06-review-20260924.md	178	0
docs/release/audit-units/715-06-review-20260924.pdf	-	-
docs/release/audit-units/715-06-skips-20260924.tsv	663	0
docs/release/audit-units/715-06-validation-20260924.tgz	-	-
docs/release/audit-units/715-06-validation-sha256-20260924.txt	1064	0
docs/security/evidence/rom-printf-integer-percent/01-thorchain-withdraw-25.05pct.png	-	-
docs/security/evidence/rom-printf-integer-percent/02-thorchain-sending-eth.png	-	-
docs/security/evidence/rom-printf-integer-percent/README.md	17	0
include/keepkey/firmware/eip712.h	8	4
include/keepkey/firmware/ethereum.h	1	0
include/keepkey/firmware/ethereum_contracts/thortx.h	13	11
include/keepkey/firmware/ethereum_contracts/zxliquidtx.h	4	4
include/keepkey/firmware/thorchain.h	2	6
include/keepkey/firmware/tiny-json.h	0	6
include/keepkey/transport/messages.options	1	1
lib/board/draw.c	1	1
lib/board/messages.c	19	3
lib/firmware/CMakeLists.txt	0	1
lib/firmware/eip712.c	377	285
lib/firmware/ethereum.c	64	10
lib/firmware/ethereum_contracts.c	1	1
lib/firmware/ethereum_contracts/zxapliquid.c	110	96
lib/firmware/ethereum_contracts/zxliquidtx.c	160	190
lib/firmware/fsm_msg_common.h	10	0
lib/firmware/fsm_msg_eos.h	6	0
lib/firmware/fsm_msg_ethereum.h	8	1
lib/firmware/fsm_msg_ripple.h	15	8
lib/firmware/recovery_cipher.c	2	0
lib/firmware/ripple.c	1	1
lib/firmware/signing.c	19	13
lib/firmware/storage.c	26	12
scripts/emulator/capture-thor-percent.py	99	0
scripts/emulator/python-keepkey-tests.sh	11	0

scripts/tests/test_usb_receive_callbacks.py	85	0
unittests/firmware/CMakeLists.txt	4	0
unittests/firmware/app_confirm.cpp	48	0
unittests/firmware/eip712.cpp	194	0
unittests/firmware/ethereum.cpp	217	0
unittests/firmware/fsm.cpp	108	20
unittests/firmware/kkconfirm_driver.h	20	0
unittests/firmware/liquidity_key_probe.c	54	0
unittests/firmware/messages_probe.c	11	0
unittests/firmware/ripple.cpp	17	0
unittests/firmware/signed_metadata.cpp	264	7
unittests/firmware/storage.cpp	98	28
unittests/firmware/usb_rx.cpp	74	0

6. Review preflight and checkpoint

The adjacent diff is code-bearing. Each security property maps to the changed paths above or is explicitly inherited. The same source supplies this PDF; all rendered pages must be checked before handoff. Record the final head, exact-head CI run/artifacts, current target match and any review delivery in the PR description and canonical claim. No merge, upstream submission, physical-device acceptance or release promotion is implied.

External review remains a distinct checkpoint. No Copilot finding is silently accepted, and no clean review is claimed before delivery on the current final code-bearing diff. The original PR #836 remains historical; the reconciled audit PR is the review target against completed Stack 05.